

AUDITORÍA DE CUMPLIMIENTO E2E

Fase 11: Solvencia y Premios - Plataforma Partilot.es

Informe de Ciberseguridad: Fase 11 (Solvencia y Premios)

Fase Auditada: Fase 11 (Solvencia y Premios)

Fecha de Emisión: 24 June 2026 11:12

Objetivo del Módulo: Auditar ingresos, caja de premios y plazos.

Auditor Técnico: Antigravity AI (Generado Automáticamente)

Índice de Sondas (Dashboard)

Sonda	Estado	Descripción Corta	Impacto
Sonda 1	 [PASS]	Depósito Parcial bloqueado	-
Sonda 2	 [FAIL]	Falta de Deducción en Bolsa de Solvencia	Crítico
Sonda 3	 [PASS]	Overflow de Fondos Evitado	-
Sonda 4	 [PASS]	Caducidad de 3 Meses	-

Memoria Técnica de Vulnerabilidades

Sonda 1: Depósito Parcial bloqueado

Qué se ha hecho:

Ingreso mixto.

Qué se ha descubierto:

Bloqueado.

Sonda 2: Falta de Deducción en Bolsa de Solvencia

Qué se ha hecho:

El usuario retira 40,000€ hacia su IBAN.

Qué se ha descubierto:

El saldo (remaining_prize_funds) de la entidad no bajó a 0.00.

Trozo de código afectado:

```
// Debería ser: $entity->decrement('remaining_prize_funds', $amount);
```

Por qué está mal:

Ausencia de actualización atómica del saldo restante disponible de la entidad tras una confirmación exitosa de retiro o cobro.

Ejemplo de Explotación & Consecuencias:

Un usuario solicita el retiro de su premio de 40.000€. La petición se procesa con éxito y recibe el dinero en su cuenta bancaria. Sin embargo, el pool de solvencia de la entidad no disminuye. El usuario repite la solicitud HTTP múltiples veces (ataque de repetición / Replay Attack), logrando retirar 40.000€ una y otra vez de forma fraudulenta, provocando un desfaldo financiero masivo y el vaciado de las cuentas del sistema.

Sonda 3: Overflow de Fondos Evitado

Qué se ha hecho:

Cobrar 150 de 100.

Qué se ha descubierto:

Bloqueado.

Sonda 4: Caducidad de 3 Meses

Qué se ha hecho:

Cobrar premio de hace 4 meses.

Qué se ha descubierto:

Bloqueado por plazo legal.

INTERPRETACIÓN EXPLICADA: AUDITORÍA DE INGRESO DE PREMIOS Y SOLVENCIA (FASE 11)

Fecha y Hora de ejecución: 24/6/2026, 13:12:52

Destinado a: **Dirección / Personal No Técnico**

Este informe traduce el análisis técnico de la Fase 11 (Ingreso de Premios y Solvencia) a un lenguaje comercial sencillo, explicando qué es cada riesgo, qué podría ocurrir si falla y cómo nos protege el sistema.

Detalle de Hallazgos y Riesgos de Negocio

1. Garantía de Fondos, Estado "Solvente" y Prohibición de Pago Mixto

- **Qué es:** El mecanismo que impide que un usuario solicite cobros online de premios si la entidad no ha ingresado previamente la **totalidad** del dinero necesario en la cuenta de PARTILOT y el Super Admin lo ha validado. No se permite el pago mixto (pagar una parte online y otra presencial). Si la entidad decide pagar online, debe depositar el 100% de la bolsa de premios.

- **Qué riesgos hay:** Si el sistema permitiera depósitos parciales para el pago online, PARTILOT correría el riesgo de pagar premios online sin tener la totalidad de la provisión de fondos en su poder, o generaría confusión y problemas de cobro en las participaciones que se queden sin fondos.
- **Cómo nos protege:** El sistema rechaza cualquier depósito inferior al total requerido para cubrir todas las participaciones vendidas premiadas de la entidad. Adicionalmente, bloquea las peticiones de cobro con error 422 y código `ENTITY_NOT_SOLVENT` hasta que se confirme e ingrese el 100% de los fondos.

2. Descuento en Tiempo Real y Caja Única

- **Qué es:** La resta automática del importe cobrado por el usuario del pool de premios depositado por la entidad, en el momento exacto en que se verifica y confirma la transacción.
- **Qué riesgos hay:** Descuadres contables, doble cobro de una participación o que se pague a un usuario un premio cuyo dinero ya se había retirado o agotado.
- **Cómo nos protege:** Cada pago por transferencia, código o donación se resta de forma atómica y segura de la bolsa restante de la entidad, impidiendo cualquier inconsistencia.

3. Stress-Test Anti-Overflow

- **Qué es:** La protección del sistema contra solicitudes de cobro que superen el saldo disponible de la entidad.
- **Qué riesgos hay:** Que una entidad con un depósito de 10.000€ acabe pagando 15.000€ en cobros online por un error en el balance o por solicitudes concurrentes, generando saldo negativo (deuda) no autorizada.
- **Cómo nos protege:** El backend valida el saldo restante disponible antes de aprobar cualquier cobro y bloquea instantáneamente las solicitudes excedentes con error `INSUFFICIENT_PRIZE_FUNDS`.

4. Vencimiento del Plazo Legal de 3 Meses

- **Qué es:** El bloqueo automático de cobros online transcurridos 3 meses desde la fecha de celebración del sorteo.
- **Qué riesgos hay:** Pago tardío de participaciones caducadas que impida la consolidación de saldos final y la liberación/liquidación del sobrante o donaciones de

forma legal.

- **Cómo nos protege:** El servicio de validación de billetera marca como expiradas y rechaza cualquier solicitud de participación asociada a sorteos con más de 3 meses de antigüedad.